

Literature Survey

Hybrid ECC-Based Mutual Authentication for Trustworthy Internet of Things Communication

Jay Kerkar

Chaitanya Kelkar

Chirag Poornamath

Yash Kolekar

Department of Information Technology

Vivekanand Education Society's Institute of Technology, Mumbai, India

Project Guide: Dr. Shanta Sondur

Department of Information Technology

Vivekanand Education Society's Institute of Technology, Mumbai, India

Base Paper: A. Al-Rasheed, R. Khan, A. Ahmad, A. Saeed, F. Alturise, and S. Alkhalaf, "A Low-Cost Hybrid Elliptic Curve Cryptography Authentication Protocol for Trustworthy Internet of Things Communication," *IEEE Transactions on Consumer Electronics*, vol. 72, no. 2, pp. 4483–4491, May 2026.
DOI: [10.1109/TCE.2026.3662053](https://doi.org/10.1109/TCE.2026.3662053)

Prepared as part of the delta-work / base-paper literature review

Contents

1	Introduction	2
2	Background and Motivation	2
2.1	The IoT Authentication Problem	2
2.2	Why Pure Asymmetric (PKI-Style) Authentication Struggles	2
2.3	Elliptic Curve Cryptography as a Lightweight Root of Trust	3
2.4	Blockchain and Distributed-Ledger Augmentation	3
3	Related Work	3
3.1	Blockchain- and Access-Control-Based Schemes	3
3.2	Public/Private-Key and Certificate-Based Schemes	3
3.3	Lightweight Hash, XOR, and Symmetric-Key Schemes	3
3.4	Machine-Learning-Assisted Intrusion Detection as a Complementary Layer	4
3.5	ECC-Based Benchmark Protocols (Direct Comparators)	4
3.6	Certificateless and Biometric-Factor Schemes	4
4	Comparative Analysis	4
4.1	Quantitative Positioning of the Base Paper	5
5	Identified Research Gaps	6
6	Conclusion	7

1 Introduction

The Internet of Things (IoT) now connects billions of resource-constrained sensors, actuators, and edge servers that exchange sensed data over shared, unsecured wireless channels [1]. Because packets traverse open media, any communicating device or server must first establish the trustworthiness of the peer it is talking to before a session begins [1]. Mutual authentication is the mechanism the field has settled on for this purpose, yet the literature repeatedly shows a tension between three competing goals: (i) strong, provable security against eavesdropping, replay, and impersonation; (ii) low communication, computation, and storage overhead suitable for constrained hardware; and (iii) generality across heterogeneous device-to-device, device-to-server, and server-to-server topologies.

This survey is organized around the base paper selected for this project: Al-Rasheed et al.’s hybrid Elliptic Curve Cryptography (ECC) authentication protocol [1], published in *IEEE Transactions on Consumer Electronics* in May 2026. The base paper proposes a two-message, challenge-response mutual authentication scheme in which ECC is used only in an offline, one-time registration phase to derive a symmetric secret key for every device and server; all online authentication traffic thereafter relies on fast symmetric-key operations and hash functions. The authors validate the scheme in OMNeT++ and report reductions of approximately 17%, 21%, and 12% in communication, processing, and storage overhead, respectively, relative to nine benchmarked prior schemes.

The remainder of this survey is organized as follows. Section 2 summarizes the technical motivation for hybrid ECC/symmetric designs in IoT authentication. Section 3 surveys prior research, grouped by the underlying security mechanism: blockchain- and access-control-based schemes, public/private-key and certificate-based schemes, lightweight hash/XOR and symmetric-key schemes, machine-learning-assisted intrusion detection as a complementary defense, and the ECC-based benchmark protocols the base paper directly compares itself against. Section 4 consolidates the surveyed work, together with the base paper’s own reported figures, into a comparative table. Section 5 distills the open research gaps — as identified both by the base paper’s authors and by our own reading — that motivate delta (extension) work. Section 6 concludes.

2 Background and Motivation

2.1 The IoT Authentication Problem

IoT devices communicate over shared, broadcast-style wireless media, which makes every session a target for eavesdropping, replay, message injection, and impersonation attacks [1]. Because IoT deployments span device-to-device, device-to-server, and server-to-server topologies at very large scale, an authentication scheme must remain lightweight and generalizable rather than tailored to a single application domain [1].

2.2 Why Pure Asymmetric (PKI-Style) Authentication Struggles

Public-key-based mutual authentication schemes that rely on full certificate infrastructures or heavyweight public/private key exchanges provide strong assurances but introduce complexity that scales poorly: key or certificate re-issuance, revocation, and chain-of-trust validation are all expensive operations that constrained IoT devices are not well suited to perform repeatedly at runtime [3].

2.3 Elliptic Curve Cryptography as a Lightweight Root of Trust

ECC provides public-key-strength guarantees with much smaller key sizes than RSA or comparable asymmetric schemes, which is why it remains the dominant primitive for constrained-device authentication design [1]. The design choice explored by the base paper — confining ECC operations to a one-time offline registration phase and deriving a symmetric session-usable secret from it — reflects a broader trend in the literature of using ECC as a root of trust while keeping the online path symmetric-key only, since scalar multiplication remains one of the more expensive operations a constrained device can perform [1].

2.4 Blockchain and Distributed-Ledger Augmentation

A parallel line of work strengthens IoT trust management by layering blockchain-based access control or ledger-backed revocation on top of the authentication process. This improves auditability and decentralization but introduces consensus and re-encryption overhead that is difficult to reconcile with the power and memory budgets of constrained sensor nodes [2].

3 Related Work

3.1 Blockchain- and Access-Control-Based Schemes

Zong et al. [2] proposed ReLAC, a decentralized, blockchain-enabled access control mechanism that grants consumer devices revocable access rights. While ReLAC achieves fine-grained, decentralized revocation, its scalability suffers at large scale because every revocation event requires key re-generation or re-encryption across the network — an overhead the base paper explicitly identifies as a limiting factor [1]. Qiu et al. [7] similarly combined blockchain with a lightweight mutual authentication scheme for the Internet of Medical Things, again trading blockchain’s auditability benefits against the computational and storage cost of ledger maintenance on constrained nodes.

3.2 Public/Private-Key and Certificate-Based Schemes

Khan et al. [3] presented a distributed, server-oriented mutual authentication scheme for automotive IoT that relies on public and private key pairs to establish trust between connected electronic devices. Although this provides a high assurance level, the base paper notes that the resulting authentication process becomes overly complex and difficult to scale for large IoT deployments [1]. Yin and Gong [8] took a related but distinct approach with a certificateless mutual authentication scheme based on digital signatures, removing the need for a full certificate authority infrastructure while still requiring signature generation and verification at both endpoints — a heavier computational profile than a purely symmetric handshake.

3.3 Lightweight Hash, XOR, and Symmetric-Key Schemes

At the opposite end of the complexity spectrum, several schemes avoid asymmetric cryptography almost entirely. Gong et al. [5] developed LCDMA, a lightweight cross-domain mutual identity authentication scheme that uses binary symmetric polynomials for key generation, substantially reducing computational cost relative to certificate- or blockchain-based alternatives. Sharma and Dhiman [9] proposed a secure addressing scheme for smart-home IoT networks in which each device is assigned a unique interface identifier derived from simple hash and XOR operations; the scheme is efficient but depends

on a centralized gateway, which the base paper flags as a scalability concern shared with several address-based designs [1]. Alshawish and Al-Haj [6] combined a hash function with AES encryption across a six-message exchange to authenticate IoT devices; the base paper observes that both the message count and the inclusion of a full AES encryption round make this approach considerably more lengthy than a minimal two-message symmetric handshake [1].

3.4 Machine-Learning-Assisted Intrusion Detection as a Complementary Layer

A distinct but related body of work treats authentication and intrusion detection as complementary rather than identical problems. Javeed et al. [4] designed an intelligent intrusion detection system for smart consumer electronics networks, while a CUDA-accelerated Bidirectional Long Short-Term Memory network has been used to classify multiple IoT attack types in real time [1]. These approaches strengthen post-authentication monitoring but do not themselves establish the initial mutual trust between a source and destination module, which remains the scope of the challenge-response schemes surveyed elsewhere in this document.

3.5 ECC-Based Benchmark Protocols (Direct Comparators)

The base paper benchmarks its proposed scheme directly against nine established ECC- and biometric-based authentication protocols, several of which recur across the wider literature as reference points for communication, computation, and storage overhead: Porambage et al.'s two-phase authentication protocol for wireless sensor networks [10]; Turkanovic et al.'s user authentication and key agreement scheme for heterogeneous ad hoc wireless sensor networks [11]; Dhillon and Kalra's lightweight biometric-based remote user authentication scheme [12]; Wang et al.'s lightweight protocol for emergency-vehicle avoidance in VANETs [13]; Jiang et al.'s chaotic-maps-based three-factor authentication scheme with biometric template privacy [14]; Challa et al.'s secure signature-based authenticated key establishment scheme for IoT applications [15] (the base paper's overhead tables also list a closely related comparator from the same signature/fuzzy-extraction family of schemes); Sadhukhan et al.'s lightweight ECC-based remote user authentication scheme [16]; and Fakroon et al.'s secure remote anonymous user authentication scheme for smart-home environments [17]. Across this group, the base paper's authors note a consistent pattern: most protocols require a minimum of four authentication messages and one-and-a-half to three times the storage footprint of the proposed two-message scheme, because each additionally carries biometric templates, chaotic-map state, or signature material rather than a single derived symmetric secret [1].

3.6 Certificateless and Biometric-Factor Schemes

Beyond the direct benchmark set, certificateless and multi-factor designs form a closely related design family. Certificateless signature schemes remove the certificate authority while retaining public-key-style authentication guarantees, but typically require more extensive per-session signature generation and verification steps than a symmetric challenge-response exchange, mirroring the overhead trade-off the base paper reports for its signature-based comparators [8, 15].

4 Comparative Analysis

Table 1 consolidates the surveyed protocols by security mechanism, principal strength, and principal limitation, extending the comparison originally presented in the base paper's Tables IV–VI [1].

4.1 Quantitative Positioning of the Base Paper

The base paper reports a total online authentication cost of two messages and 264 bits of transmitted payload, against a minimum of four messages required by every one of the nine benchmarked schemes [1]. In its OMNeT++ evaluation across increasing network sizes (300–1800 nodes), the proposed scheme consistently shows the lowest communication overhead, the lowest processing time, and the lowest storage cost among the compared algorithms, translating to the reported approximate reductions of 17% (communication), 21% (processing), and 12% (storage) [1].

Table 1: Comparative summary of surveyed IoT mutual authentication schemes.

Study	Mechanism	Strength	Limitation
Zong et al. [2] (ReLAC)	Blockchain + revocable access control	Decentralized, fine-grained revocation	Poor scalability; revocation needs key regeneration
Khan et al. [3]	Distributed public/private key scheme	Strong, server-oriented trust guarantees	High complexity at large scale
Yin & Gong [8]	Certificateless signatures	No CA infrastructure required	Signature overhead per session
Gong et al. [5] (LCDMA)	Binary symmetric polynomials	Greatly reduced computational cost	Cross-domain key distribution complexity
Sharma & Dhillon [9]	Hash + XOR addressing	Simple, low-cost identifier scheme	Centralized gateway dependency
Alshawish & Al-Haj [6]	Hash + AES, six messages	Confidentiality via AES	Lengthy six-message exchange
Qiu et al. [7]	Blockchain-based (medical IoT)	Strong auditability	Blockchain overhead unsuitable for low-power nodes
Porambage et al. [10]	Two-phase ECC authentication	Establishes early IoT authentication baseline	Higher message/communication count
Turkanovic et al. [11]	User authentication + key agreement	Suited to heterogeneous WSNs	Higher storage cost
Dhillon & Kalra [12]	Biometric-based remote authentication	Adds a biometric trust factor	Biometric template storage overhead
Jiang et al. [14]	Chaotic-maps three-factor scheme	Preserves biometric template privacy	Chaotic-map computation cost
Challa et al. [15]	Signature-based key establishment (fuzzy extraction)	Strong authenticated key establishment	Higher processing cost (fuzzy extraction)
Sadhukhan et al. [16]	ECC-based remote user authentication	Lightweight relative to PKI schemes	Higher storage than proposed scheme
Fakroon et al. [17]	Anonymous remote user authentication	Preserves user anonymity	Larger communication overhead

continued on next page

Table 1 – *continued from previous page*

Study	Mechanism	Strength	Limitation
Base paper [1]	Hybrid ECC (offline) + symmetric/hash (online)	Two-message hand-shake; lowest reported comm./proc./storage cost	Static devices only; single TA; no revocation

5 Identified Research Gaps

Synthesizing the surveyed literature together with the base paper’s own stated scope and limitations, the following gaps emerge as candidates for extension work:

1. **Static-device assumption.** The base paper’s simulation setup and conclusion both explicitly restrict the proposed scheme to static devices and servers, and the authors explicitly flag mobility support as future work [1]. Nearly every ECC-based comparator surveyed here (Porambage et al. [10], Turkanovic et al. [11]) was likewise evaluated in largely static wireless sensor network settings, leaving mobile device-to-device and vehicular authentication under this hybrid model comparatively unexplored.
2. **Single, centralized Trusted Authority (TA).** All key material in the base paper’s offline registration phase is issued by one TA, and the threat model explicitly assumes the offline phase cannot be compromised [1]. No mechanism is described for TA failure, TA compromise, or distributing trust across multiple authorities — a gap also present in several PKI-style comparators [3] but only partially addressed by the blockchain-based alternatives surveyed above [2, 7], which introduce their own scalability costs in exchange for decentralization.
3. **Absence of an explicit key-revocation mechanism.** The base paper’s registration phase establishes a persistent, offline-issued secret key λ_X for every device and server, but neither the protocol description nor the security analysis specifies how a lost, stolen, or compromised device’s key would be revoked or reissued without repeating full offline registration. This mirrors a limitation the base paper itself identifies in blockchain-based revocation schemes such as ReLAC [2], where revocation requires expensive key regeneration — the base paper’s own design does not yet offer a lighter-weight alternative.
4. **Scalability of pairwise/offline storage.** Because every device and server stores the secret-key list of trusted peers exchanged during registration [1], storage growth with the number of trusted peers should be characterized more precisely as network size increases, particularly relative to the addressing-based scheme of Sharma and Dhiman [9] and the certificateless designs of Yin and Gong [8], which manage peer trust differently.
5. **Validation limited to network-level simulation.** The security and performance claims are validated exclusively in OMNeT++ [1]; unlike field- or hardware-level benchmarking reported for some comparator schemes, no physical constrained-device (e.g., microcontroller or single-board computer) timing measurements are presented, leaving actual energy and latency behavior on real IoT hardware as an open empirical question.
6. **No formal machine-verified security proof.** The base paper’s security argument is presented narratively, in terms of resistance to specific attack classes, rather than through a formal verification tool

(e.g., ProVerif, Tamarin, or the Random Oracle Model treatment used by some certificateless comparators [8]). A machine-checked proof would strengthen the scheme’s assurance claims relative to the formally verified alternatives in this space.

Among these, gap 1 (mobility support) and gap 3 (key revocation) are the most directly actionable for a cryptography-focused extension: both are explicitly named as limitations by the base paper’s own authors, both have related prior work to draw from within the surveyed literature (mobility-aware VANET protocols such as Wang et al. [13]; blockchain-based revocation such as ReLAC [2]), and both are self-contained protocol-design problems that can be evaluated using the same OMNeT++ methodology already established by the base paper, enabling direct, credible comparison against its reported figures.

6 Conclusion

This survey has reviewed the landscape of ECC-based and complementary lightweight mutual authentication schemes for the Internet of Things, situating the base paper — Al-Rasheed et al.’s hybrid ECC/symmetric authentication protocol [1] — within that landscape. Across blockchain-augmented, certificate- or signature-based, hash/XOR-based, and biometric-factor approaches, a consistent tension recurs between authentication strength and communication/processing/storage overhead. The base paper’s contribution is to resolve this tension by confining ECC operations to a one-time offline registration phase and relying on a minimal two-message symmetric challenge-response exchange online, achieving the lowest reported overhead among the nine schemes it benchmarks against. The paper’s own authors identify mobility support as its most significant unresolved limitation, and this survey additionally identifies the absence of a key-revocation mechanism and the reliance on a single, centralized trusted authority as closely related and well-scoped gaps — together representing the most promising directions for extension work within the cryptography domain.

References

- [1] A. Al-Rasheed, R. Khan, A. Ahmad, A. Saeed, F. Alturise, and S. Alkhalaf, "A Low-Cost Hybrid Elliptic Curve Cryptography Authentication Protocol for Trustworthy Internet of Things Communication," *IEEE Trans. Consum. Electron.*, vol. 72, no. 2, pp. 4483–4491, May 2026, doi: 10.1109/TCE.2026.3662053.
- [2] J. Zong, C. Wang, J. Shen, C. Su, and W. Wang, "ReLAC: Revocable and lightweight access control with blockchain for smart consumer electronics," *IEEE Trans. Consum. Electron.*, vol. 70, no. 1, pp. 3994–4004, Feb. 2024.
- [3] M. N. Khan, H. U. Rahman, T. Hussain, B. Yang, and S. M. Qaisar, "Enabling trust in automotive IoT: Lightweight mutual authentication scheme for electronic connected devices in Internet of Things," *IEEE Trans. Consum. Electron.*, vol. 70, no. 3, pp. 5065–5078, Aug. 2024.
- [4] D. Javeed, M. S. Saeed, I. Ahmad, P. Kumar, A. Jolfaei, and M. Tahir, "An intelligent intrusion detection system for smart consumer electronics network," *IEEE Trans. Consum. Electron.*, vol. 69, no. 4, pp. 906–913, Apr. 2023.
- [5] B. Gong, G. Zheng, M. Waqas, S. Tu, and S. Chen, "LCDMA: Lightweight cross-domain mutual identity authentication scheme for Internet of Things," *IEEE Internet Things J.*, vol. 10, no. 14, pp. 12590–12602, Jul. 2023.
- [6] I. Alshawish and A. Al-Haj, "An efficient mutual authentication scheme for IoT systems," *J. Supercomput.*, vol. 78, no. 14, pp. 16056–16087, Sep. 2022.
- [7] S. Qiu, J. Li, X. Di, X. Li, Y. Wu, and M. Ibrahim, "Lightweight mutual authentication scheme based on blockchain for Internet of Medical Things," *IEEE Internet Things J.*, vol. 12, no. 7, pp. 8848–8861, Apr. 2025.
- [8] D. Yin and B. Gong, "A lightweight certificateless mutual authentication scheme based on signatures for IIoT," *IEEE Internet Things J.*, vol. 11, no. 16, pp. 26852–26865, Aug. 2024.
- [9] N. Sharma and P. Dhiman, "A secure addressing mutual authentication scheme for smart IoT home network," *Multimedia Tools Appl.*, vol. 84, no. 22, pp. 25111–25143, Aug. 2024.
- [10] P. Porambage, C. Schmitt, P. Kumar, A. Gurtov, and M. Ylianttila, "Two-phase authentication protocol for wireless sensor networks in distributed IoT applications," in *Proc. IEEE Wireless Commun. Netw. Conf. (WCNC)*, Apr. 2014, pp. 2728–2733.
- [11] M. Turkanović, B. Brumen, and M. Hölbl, "A novel user authentication and key agreement scheme for heterogeneous ad hoc wireless sensor networks, based on the Internet of Things notion," *Ad Hoc Netw.*, vol. 20, pp. 96–112, Sep. 2014.
- [12] P. K. Dhillon and S. Kalra, "A lightweight biometrics based remote user authentication scheme for IoT services," *J. Inf. Secur. Appl.*, vol. 34, pp. 255–270, Jun. 2017.
- [13] C. Wang, R. Huang, J. Shen, J. Liu, P. Vijayakumar, and N. Kumar, "A novel lightweight authentication protocol for emergency vehicle avoidance in VANETs," *IEEE Internet Things J.*, vol. 8, no. 18, pp. 14248–14257, Sep. 2021.
- [14] Q. Jiang, F. Wei, S. Fu, J. Ma, G. Li, and A. Alelaiwi, "Robust extended chaotic maps-based three-factor authentication scheme preserving biometric template privacy," *Nonlinear Dyn.*, vol. 83, no. 4, pp. 2085–2101, Mar. 2016.
- [15] S. Challa *et al.*, "Secure signature-based authenticated key establishment scheme for future IoT applications," *IEEE Access*, vol. 5, pp. 3028–3043, 2017.

- [16] D. Sadhukhan, S. Ray, G. P. Biswas, M. K. Khan, and M. Dasgupta, “A lightweight remote user authentication scheme for IoT communication using elliptic curve cryptography,” *J. Supercomput.*, vol. 77, no. 2, pp. 1114–1151, Feb. 2021.
- [17] M. Fakroon, M. Alshahrani, F. Gebali, and I. Traore, “Secure remote anonymous user authentication scheme for smart home environment,” *Internet of Things*, vol. 9, Art. no. 100158, Mar. 2020.